9 · Supplier CRA clause pack

This pack gives contract clauses that let you meet your Art 13(5) due diligence duty on third-party components and your Art 13(6) duty to report component vulnerabilities upstream. Add it as a schedule to master agreements for suppliers of software, firmware, hardware with firmware, integrated SaaS or development services. It is a starting draft for legal review, not signed-off contract wording.

At a glance

Item	Detail
Legal basis	Art 13(5) due diligence; Art 13(6) upstream reporting; Art 13(8) support period; Annex I Part II(1) SBOM; Art 14 reporting
Needed for	Every supplier of an in-scope component, ranked by component risk (Recital 34)
Owner	Head of procurement
Approver	Legal counsel, with the product security officer for clauses 2-6
When to create	At contract award or renewal; before a new component enters the intake gate
When to update	At renewal, at each major component version, and when the product support period changes
Retention	Life of contract, plus 10 years after placing or the support period, whichever is longer, where it evidences diligence (Art 13(13))
Feeds	Template 2 (component risks), Template 3 (Art 13(8) third-party support), Template 4 (Annex VII pt 2(b) SBOM), Template 7 (component reports), Template 8 (Art 14 inputs)

How to complete

1. List in-scope suppliers and rank them by the risk of what they supply. Start with security-relevant components.

2. Pick Must and Should clauses per supplier from the clause index. Clauses never replace diligence.
3. Fill the placeholders. Take the support-period end date from Template 3 and the notification hours from Template 8.
4. Send the schedule with the supplier questionnaire. Ask for Commit, Partial or Refuse against each clause.
5. Score responses with the scoring table. Record the decision in the contract register and the component intake gate.
6. Legal reviews the final wording against the governing law before signature.

Template

Clause index

Clause	Purpose	CRA hook	Must / Should	Fallback if supplier refuses
1 Definitions	Ties contract terms to CRA terms	Art 3(20), 3(30), 3(42)	Must	Attach a definitions annex by reference
2 Vulnerability notification	Early notice so our 24 h and 72 h clocks can be met	Art 13(5), Art 14(2) and (4), Annex I Part II(6)	Must	Monitor supplier advisories, EUVD, NVD and OSV ourselves; intake gate rates component high risk
3 Security updates	Fixes for the whole product support period	Art 13(8), 13(9), Annex I Part II(2), (7), (8)	Must	Source code escrow or our own patching; documented replacement plan

Clause	Purpose	CRA hook	Must / Should	Fallback if supplier refuses
4 SBOM delivery	Component depth in our SBOM	Annex I Part II(1); Annex VII pts 2(b), 8; Art 13(25)	Must	Binary SCA on the delivered artefact; we generate the SBOM and mark known unknowns
5 Secure development, evidence and audit	Evidence for diligence and for reasoned requests	Art 13(5), 13(22); Recital 34; supports Annex VIII Module B pt 8 (notified-body audits of our processes)	Must for security-relevant components; Should otherwise	Questionnaire answers, scoped certificates and our own testing (fuzzing, penetration test)
6 Incident cooperation	Inputs for Art 14 reports and user information	Art 14(2), (4), (6), (8)	Must	Named contact on best efforts; build data from our own telemetry
7 End-of-life and cessation	Time to migrate before support ends	Art 13(8), 13(19), 13(23)	Must	Last-time buy; escrow; earlier redesign
8 Substantial change notice	Input to our substantial modification test	Art 3(30); guidance pts 108-110; supports our Annex VIII Module B pt 7 duty to inform the notified body	Should	Our release gate assesses every supplier release (Template 10)
9 Flow-down	Same duties on sub-suppliers	Art 13(5); Art 23 traceability	Should	Supplier lists sub-suppliers of security-relevant parts

Clause	Purpose	CRA hook	Must / Should	Fallback if supplier refuses
10 Open-source components	Keeps responsibility and upstream channel with us	Art 13(5), 13(6); guidance pts 86-88, 222-229	Must	None needed; we run the upstream channel
11 Confidentiality of vulnerability information	Embargo without blocking legal reports	Annex I Part II(4), (5); Art 14(8)	Must	Supplier CVD policy governs, with embargo dates agreed in writing
12 Liability	Cost allocation	None; we remain responsible as manufacturer	[Negotiated]	Commercial decision recorded by legal

Clause wording

Starting draft for legal review. Adapt numbering and defined terms to your master agreement. "Customer" is the manufacturer; "CRA" is Regulation (EU) 2024/2847.

1 Definitions. 1.1 "Component" means [the software, firmware, hardware with firmware, service or development deliverable] supplied under this Agreement for integration into the Products. 1.2 "Products" means [the Customer products listed in Annex A]. 1.3 "Actively Exploited Vulnerability", "Support Period" and "Substantial Modification" have the meanings in Article 3(42), 3(20) and 3(30) of the CRA. 1.4 "Severe Incident" means an incident meeting the test in Article 14(5) of the CRA. 1.5 "Aware" means having a reasonable degree of certainty after an initial assessment.

2 Vulnerability notification. 2.1 The Supplier shall notify the Customer of any Actively Exploited Vulnerability or Severe Incident affecting a Component within [x hours, suggested 12] of becoming Aware. 2.2 For other vulnerabilities rated [high or critical], notice is due within [5] business days; for all others within [30] days. 2.3 Notices go to [PSIRT mailbox] and [24/7 telephone]. They state: affected Component versions; description and severity with rating method; exploitation status and evidence; fixes, workarounds or mitigations; expected fix date; and the Supplier's disclosure plan. 2.4 The Supplier shall notify the Customer no later than it publishes any advisory on a Component vulnerability. 2.5 While an Actively Exploited Vulnerability is unmitigated, the Supplier shall update the Customer every [24] hours.

3 Security updates. 3.1 The Supplier shall declare in writing, at delivery, the support period for each Component version. 3.2 The Supplier shall provide security updates for each Component version until at least [date = end of the Customer's declared support period for the last Product unit placed with that version]. 3.3 Security updates shall be [free of charge], provided without delay in relation to the risk, and separate from functionality updates where technically feasible. 3.4 Updates shall be signed using [method] and come with advisory information sufficient for the Customer's own advisories. 3.5 The Supplier shall keep each security update available to the Customer for at least [10] years after issue.

4 SBOM delivery. 4.1 With each release of a Component, the Supplier shall deliver a machine-readable SBOM in [CycloneDX 1.6 or later / SPDX 3.0.1 or later]. 4.2 The SBOM covers at least top-level dependencies and [recurses to the first component outside the delivery scope, per BSI TR-03183-2 v2.1.0]. 4.3 Each entry states creator, name, version, licence and [SHA-512 hash], and marks known unknowns. 4.4 The SBOM shall not contain vulnerability information. The Supplier provides vulnerability status separately in [CSAF 2.0 with VEX]. 4.5 The Customer may place the SBOM in its technical documentation and supply it to a market surveillance authority or notified body. It shall not otherwise publish it without consent.

5 Secure development, evidence and audit. 5.1 The Supplier shall develop Components under a documented secure development framework [IEC 62443-4-1 / NIST SSDF / OWASP SAMM] and test them [at each release and on threat-driven triggers]. 5.2 Within [30] days of request, or [5] business days after a reasoned request from an authority or notified body, the Supplier shall provide: its EU declaration of conformity where the Component is itself a CRA product; extracts of its risk assessment and technical documentation; test reports; and certificates with scope statements. 5.3 The Customer [or a notified body acting for it] may audit the Supplier's vulnerability handling for the Components [once a year and after an Actively Exploited Vulnerability] on [20] business days' notice. 5.4 The Supplier shall cooperate with the Customer's responses to market surveillance authorities and notified bodies.

6 Incident cooperation. 6.1 Where the Customer must notify under Article 14 of the CRA, the Supplier shall promptly provide in [English]: affected versions and configurations; the nature of the exploit and the vulnerability; measures taken and measures users can take; root cause; severity and impact; any information on a malicious actor; and details and date of the fix. 6.2 The Supplier shall name a [24/7] contact who responds within [4] hours. 6.3 The Supplier shall answer requests for intermediate updates within [x hours]. 6.4 The Supplier shall not contact the Customer's users or any CSIRT about the Products without the Customer's agreement. Where the Supplier has its own legal reporting duty, it shall tell the Customer at the same time.

7 End-of-life and cessation. 7.1 The Supplier shall give at least [24] months' written notice before ending security updates or supply of a Component version, with a last-time-buy option and a migration path. 7.2 The Supplier shall give at least [6] months' notice before ceasing operations, and immediate notice of insolvency. It shall then [release escrowed source code, build tooling and signing arrangements] so the Customer can continue security updates.

8 Substantial change notice. 8.1 The Supplier shall give at least [90] days' notice of any change that may affect a Component's security properties. This includes new interfaces, protocols or remote services; changed cryptography or key management; new or changed dependencies; changed data flows; and changed intended use. 8.2 The notice includes the Supplier's security impact assessment. 8.3 Security updates that only fix vulnerabilities need no advance notice.

9 Flow-down. 9.1 The Supplier shall impose obligations no less protective than clauses 2 to 8 and 11 on sub-suppliers of security-relevant parts of the Components. 9.2 On request, the Supplier shall identify those sub-suppliers and the parts they supply. 9.3 The Supplier remains responsible for its sub-suppliers' performance.

10 Open-source components. 10.1 Nothing in this Schedule transfers the Customer's responsibility for the Products to the Supplier or to any open-source maintainer. 10.2 Where a Component contains open-source software, the Supplier shall track and apply upstream fixes. It shall report vulnerabilities it finds to the maintainer through the maintainer's disclosure channel. 10.3 The Supplier agrees that fixes either party develops to open-source code may be shared upstream in licence-compatible, machine-readable form. The Customer's [PSIRT or OSPO] coordinates this.

Internal note: open source taken directly from a project has no supplier contract. The component intake gate and your PSIRT's upstream channel cover it. The Art 13(6) duty applies from 11 Dec 2027; it ends where the maintainer already knows or no maintainer exists (guidance pts 222-229). The duty to remediate remains.

11 Confidentiality of vulnerability information. 11.1 Each party shall treat unpublished vulnerability information as Confidential Information. It may use it only to assess, fix, report or disclose the vulnerability. 11.2 The parties shall agree embargo dates, joint advisory timing, CVE or EUVD identifiers, and who informs users. 11.3 Confidentiality never prevents a party from meeting a legal reporting duty, including Article 14 of the CRA, or from informing a market surveillance authority, CSIRT, ENISA or notified body. 11.4 The Supplier shall not publish an advisory affecting the Products before the agreed date unless [the vulnerability is actively exploited and the Customer has been notified].

12 Liability. 12.1 [Allocation of remediation, withdrawal and recall costs caused by Supplier breach of this Schedule: negotiated.] 12.2 [Cap: negotiated; consider a separate cap for clauses 2, 3, 4 and 11.] 12.3 The parties acknowledge that the Customer remains

responsible as manufacturer under the CRA. Legal to confirm whether regulatory fines are recoverable under the governing law.

Supplier response scoring

Score against the component's risk, not a fixed pass mark (Recital 34). Use the same scale as the supplier questionnaire.

Response	Meaning	Action	Record
Commit	Accepts the clause as drafted or with minor edits	Accept; sign	Contract register; intake gate "approved"
Partial	Accepts in part, for example a longer notice time or no audit right	Mitigate with the clause's fallback; review at renewal	Intake gate "approved with conditions"; compensating control named
Refuse	Rejects a Must clause	Component rated high risk; documented exit plan; escalate to the procurement council	Intake gate "high risk"; exit plan owner and date
No answer in [30] days	No response	Treat as Refuse	As for Refuse

Example: L2 Smart Lock (illustrative)

Example Group has 41 in-scope suppliers; 6 are on CRA clauses (15%). The target is the top 15 by Jan 2027 and all 41 by Jun 2027.

Supplier type	Component risk	Must clauses	Response	Action
Wireless module vendor (BLE and Wi-Fi firmware)	High: unlock path	1-7, 10, 11	Partial: 48 h notice offered, not 12 h	Accept with own EUVD and advisory monitoring; renegotiate at renewal
Commercial RTOS and crypto library vendor	High: key storage	1-7, 10, 11	Commit	Sign; add to SBOM depth check

Supplier type	Component risk	Must clauses	Response	Action
Contractor building the access-management cloud	High: remote data processing	1-9, 11	Commit	Sign; flow down to its hosting provider
Lock body and motor maker (no firmware)	Out of clause scope	None	Not applicable	No CRA schedule

Common mistakes

- Treating signed clauses as the diligence. Clauses do not replace it; refusers go to the intake gate as high risk with an exit plan.
- Assuming integration moves compliance to the supplier or the open-source project. You stay responsible for the product in its entirety (guidance pts 86-88).
- Accepting a supplier support period shorter than yours. An unsupported component must be replaced or patched by you (FAQ Section 4).
- Accepting manifest-only SBOMs. Run binary SCA on the shipped artefact, because manifests miss embedded components.
- Letting a supplier publish before telling you. Its advisory can start your Art 14 clock unseen.

Template 9 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.